



WHITEPAPER · NO. 001

A PRACTICAL FRAMEWORK

SR 11-7 compliance for *regulated AI agents.*

The framework holds. The artifacts do not. Here are the five places SR 11-7 strains under AI agents, and the artifact that closes each gap.

ASHISH K. SAXENA
FOUNDER · CAVENTIA

2026 · FOR CHIEF MODEL RISK OFFICERS AT US BANKS

CAVENTIA, INC. (IN FORMATION) · CAVENTIA.COM

cavēre necesse est

Executive Summary

In April 2011 the Federal Reserve and the OCC published SR 11-7, "Guidance on Model Risk Management." The framework has held for fifteen years across statistical models, machine learning models and the first wave of deep learning models in banking. It is now being applied to large language model agents.

The framework's three pillars (development, validation, ongoing monitoring) survive that translation. The implementation artifacts do not.

This paper names the five specific places SR 11-7's expected artifacts strain when the underlying model is an AI agent built on a foundation model. For each, it describes what examiners will find unsatisfactory in a 2026 exam and the concrete artifact that closes the gap.

The five breakdowns are non-determinism, prompt-as-feature, tool use and emergent behavior, model provider opacity and continuous capability evolution. The fixes share a common data substrate: a versioned, replayable audit log of every agent decision. This paper calls it the audit-trail spine. Once the spine exists, all five SR 11-7 artifacts assemble from it.

This paper is for the Chief Model Risk Officer at a \$10B+ AUM US bank who is being asked to approve AI agents into production while the next OCC exam is twelve months out. It is a practical framework. The appendices include an examiner-readiness checklist, a section-by-section SR 11-7 mapping and a glossary of the terms introduced.

Table of Contents

- I. The Translation Problem
- II. The Five Breakdowns
 - 1. Non-determinism
 - 2. Prompt as Feature
 - 3. Tool Use and Emergent Behavior
 - 4. Model Provider Opacity
 - 5. Continuous Capability Evolution
- III. The Audit-Trail Spine
- IV. Implementation Roadmap
- Appendix A: Examiner Readiness Checklist
- Appendix B: SR 11-7 Section Mapping
- Appendix C: Glossary
- Talk to the Founder
- About the Author
- References

I. The Translation Problem

Your business unit walked in this quarter with a new AI agent. The next OCC exam is twelve months out. You read SR 11-7 alongside the agent's documentation and the framework still feels sound. The artifacts the framework asks for do not exist.

This is the problem this paper addresses.

SR 11-7 was written in April 2011. The OCC published the parallel bulletin, OCC 2011-12, the same day. Together they constitute the senior supervisory guidance on how US banks manage the risk of using models in decisions. The guidance has held with minor refinements through three regulatory administrations.

It rests on three pillars.

First, **development**. A model's data, methodology and assumptions are documented. The model has an owner. The owner can answer the question "what does this model do and how" without consulting a vendor.

Second, **validation**. An independent team verifies the model's design, implementation and ongoing performance. The guidance refers to this as "effective challenge." Validation is not a one-time exercise; it recurs at material change events and on a defined cadence.

Third, **ongoing monitoring**. Production performance is tracked against expected behavior. Material drift triggers re-validation. The monitoring function is owned by the second line of defense and read by the third line.

These pillars are sound. They apply unchanged to large language model agents. A CMRO can read SR 11-7 alongside the most ambitious AI agent in their organization and conclude, correctly, that the agent should have an owner, an independent validator and an ongoing monitoring program.

The translation breaks not at the pillar level. It breaks at the artifact level.

SR 11-7's expectations were calibrated to a specific class of model: one with a documented input space, an inspectable algorithm, a reproducible output and a stable behavior surface. Traditional statistical and machine learning models satisfy all four properties. AI agents satisfy none of them.

The implications are not theoretical. Model risk failures cost real money. The Wells Fargo 2018 consent order specifically cited "deficiencies in its enterprise-wide compliance and operational risk management program," including failures in model risk governance. Knight Capital's 2012 \$440 million loss in 45 minutes was downstream of an inadequately validated deployment of automated decisioning logic. An AI agent operating in production today with no SR 11-7-compliant documentation pack is exactly the kind of exposure those incidents teach against.

This paper is about that gap. It names five places in SR 11-7's expected artifacts where the agent context breaks the underlying assumption. For each, it describes what an OCC examiner will write in a finding and what artifact the bank should be producing instead.

The fix is not to push back on the framework. SR 11-7 is durable. The parts of it that strain under AI agents are the implementation artifacts, not the pillars. The fix is to produce a new set of artifacts that satisfy the framework's expectations using the data and structure an AI agent does produce.

II. The Five Breakdowns

1. Non-determinism

The expectation. SR 11-7 Section III on Model Development, Implementation and Use asks that a model's development be documented in a way that supports reproducibility. The implicit contract is that running the model again on the same input yields the same output. Validation depends on this contract. An independent team cannot validate a model whose output it cannot reproduce.

The breakdown. Foundation-model-based agents do not satisfy reproducibility. Even with sampling temperature set to zero, identical prompts produce different outputs across several axes:

- Provider model versions. Foundation-model providers have repeatedly shipped updates that change behavior on identical inputs without prior notice to customers.
- Infrastructure-level non-determinism. CUDA kernel scheduling, floating-point reduction order and batch composition all introduce small variations.
- Minor input perturbations. A trailing space, a different timestamp formatting or a non-printable character can shift output.

The major foundation-model providers have all confirmed in their public documentation that bit-exact output reproducibility is not a guarantee of their hosted APIs.

Examiner exposure. An examiner who asks "show me the validation evidence for this agent" expects a binder. In that binder they expect reproducibility tests: same input, same output, dated and signed. When the bank's documentation includes the line "agent output varies across calls due to non-determinism," the examiner reads that as "this model has not been validated under SR 11-7's Section III documentation expectations." That is a finding.

The fix: behavioral envelope validation. Validation shifts from "the model produces output Y on input X" to "the model produces outputs within a defined behavioral envelope on inputs from a defined representative distribution."

Behavioral envelope. A statistical specification of acceptable agent behavior over a defined input distribution, written and signed before deployment, tested in production and triggering re-validation when violated.

For classification-style agents, the envelope is a distribution of decisions across input segments, including protected classes for fair lending purposes. For generation-style agents, the envelope is bounded variance in refusal rate, length, refusal-by-segment and content category. For tool-call-style agents, the envelope is the enumeration of tools the agent is permitted to select, with bounded frequency expectations for each.

The envelope specification is the new artifact. It is dated, versioned and signed by the second line of defense. When the envelope is violated in production, that is a re-validation trigger. The envelope replaces reproducibility as the validation contract. It is more honest than the original contract for this new class of models.

Ask your second line: do we have a behavioral envelope specification for any production agent today?

2. Prompt as Feature

The expectation. SR 11-7 Section IV on Model Validation describes feature-level monitoring as part of ongoing performance assessment. The institution must document each feature, monitor its distribution in production and verify that feature contributions are stable. Disparate impact analysis under ECOA hangs off this expectation. The bank must be able to attribute a decision to specific feature values and check those features for protected-class effects.

The breakdown. AI agents do not have features in the traditional sense. The system prompt is a feature. The user input is a feature. Both are paragraphs of text. Neither fits into a feature matrix. Neither has a distribution that can be summarized in a histogram. Neither permits direct attribution analysis at the individual-feature level.

Examiner exposure. When the examiner asks for feature-importance analysis and disparate impact assessment, the bank produces nothing comparable to what was produced for a credit scorecard. The model risk function explains that the model is an LLM and feature importance does not apply.

The examiner writes a finding on Section IV monitoring expectations and a parallel concern under Regulation B implementing ECOA.

The fix: versioned prompt artifacts and population-level monitoring. The system prompt becomes a versioned artifact, treated as a model component:

- SHA-256 hashed at each production change
- Stored alongside the agent version in the model inventory
- Cited as evidence in the model card
- Subject to change control review before deployment

Feature-importance analysis is replaced by **population-level outcome monitoring**. Track decisions by demographic segment at the population level, not at the individual-feature level. Disparate impact analysis runs on outcomes against the appropriate reference population.

This satisfies SR 11-7's monitoring expectation and the ECOA disparate-impact expectation simultaneously. The artifact is a population-level bias report, dated and versioned, signed by the second line.

Ask your second line: when did we last hash the system prompt for our highest-risk agent?

3. Tool Use and Emergent Behavior

The expectation. SR 11-7 Section IV, in its evaluation-of-conceptual-soundness discussion, calls for pre-deployment behavioral specification. The institution must document the model's expected behavior under representative inputs, including edge cases. Validation tests against this specification before deployment.

The breakdown. Modern AI agents call tools. APIs, databases, vector stores, other models, search engines. The agent decides which tool to call, with what arguments, in what order. Tool selection is emergent. The same agent on the same input may use different tools on different days. Pre-deployment behavioral specification cannot enumerate every execution path.

The behavior surface is not bounded by the inputs the validation team tested. A small wording change in the system prompt or a silent provider update can shift tool-selection behavior across the production fleet between Monday and Tuesday.

Examiner exposure. The examiner asks how a specific decision was reached. The bank produces a model card describing the agent's expected behavior. The card does not match what happened in production for the specific decision under review. The examiner writes a finding on Section IV conceptual soundness.

The fix: production trace as audit artifact. Validation shifts from "predict what the agent will do" to "make what the agent does auditable." Every tool call is captured in the production system: timestamp, tool name, input arguments, return value, position in the call sequence.

The captured trace becomes the audit artifact. When an examiner asks "how did the agent decide this loan," the bank produces the trace. The trace is the evidence. The model card describes the trace structure, not the trace content.

This is a fundamental shift in what validation evidence looks like. Pre-deployment specification gives way to post-deployment reconstruction. SR 11-7 Section IV's intent is preserved. The bank can answer the examiner's question. The mechanism is different from what the guidance anticipated, but the answer is more complete than the original mechanism would have provided.

Ask your second line: can we produce the tool-call trace for one production decision, right now?

4. Model Provider Opacity

The expectation. SR 11-7 Section III requires that the model card document the model's training data, hyperparameters, validation methodology and developer. When the bank trains the model, this is straightforward.

The breakdown. When the bank uses a foundation model behind an API, the model card stops at the API boundary. Whether the bank uses Claude on AWS Bedrock, GPT-4o on Azure or Gemini on Vertex, the layer the bank documents is its own prompts, retrieval architecture and post-processing. Training data, hyperparameters and validation methodology for the foundation model are proprietary to the provider. The provider supplies its own model card. The bank cannot re-derive or audit it.

Examiner exposure. Section V on Governance, Policies and Controls permits this. The expectation under Section V's external-resources discussion is that the bank documents its reliance on a vendor model and validates its use of that model within the bank's own decisioning system. Banks have

generally satisfied Section V for hosted scoring services and SaaS analytics products. The gap with foundation models is that the vendor model has more unknown surface area than the products Section V was written for.

The examiner expectation is not itself the failure mode. The failure mode is when the bank's model card is silent about which layer (your layer versus vendor layer) owns which control. The examiner cannot allocate accountability between the two. That ambiguity is what produces the finding.

The fix: two-layer model card. Documentation explicitly distinguishes:

- **Your layer.** Prompts, retrieval architecture, post-processing logic, deployment configuration, monitoring thresholds. Documented in full as your model under Section III.
- **Vendor layer.** Foundation model name, version, provider, contractual representations, change-notification clauses. Documented under Section V's vendor-model framework.

When the vendor's model version changes, that is a vendor-model change. Under Section V, vendor-model changes require re-evaluation. The bank's re-validation gate fires on a vendor-version change the same way it fires on a feature change in a self-trained model.

The artifact is a layered model card with version pins on both layers and a defined re-validation trigger for vendor-layer changes. The card explicitly states which controls live at which layer. Examiners can read it and allocate accountability without ambiguity.

A note on self-hosted open-weight alternatives. Some banks are evaluating self-hosted open-weight models (Llama 3.1, Mistral Large and successors) as a way to collapse the two-layer card back into a single-layer card. The trade-off is that the bank now owns the full model lifecycle: training data lineage, fine-tuning logs, deployment infrastructure, security patching. Whether this is a net reduction in model risk depends on the institution's ML operations maturity. For banks without a deep ML platform team, the hosted-model two-layer card is the more honest accounting of where the risk actually sits.

Ask your second line: which controls in our model card live at our layer and which at the vendor's?

5. Continuous Capability Evolution

The expectation. SR 11-7 Section IV's ongoing-monitoring expectations require that material model behavior changes be detected and trigger re-validation. The implementation assumes the bank decides when material changes occur. The bank deploys a new feature. The bank retrains the model. The bank changes the data pipeline. The bank is the actor.

The breakdown. Foundation-model providers ship updates the bank did not author. Some of those updates change behavior on identical inputs. Providers have, on multiple occasions, released production model updates that materially shifted agent behavior across regulated workflows. The bank did not initiate the change. The bank did not test for it. The bank found out by reading the provider's release notes or, less ideally, by observing production drift.

Examiner exposure. The institution's "validated" stamp ages quickly. An examiner reading the validation date in the model card sees "validated 2026-01-15." The model has since received three provider updates. The examiner asks for re-validation evidence on each update. There is none. Finding on Section IV ongoing monitoring.

The fix: version pinning and contractual notification. Two complementary controls.

First, **version pinning.** Agents in production are bound to specific provider model versions through the API call configuration. Updates do not auto-propagate. The bank's deployment pipeline holds the version pin and enforces it at every request.

Second, **behavior-change notification clauses.** The bank's vendor contract requires the provider to notify the bank of behavior-impacting model updates with sufficient lead time for re-validation. The lead time is contractually specified; thirty days is a reasonable floor. This is a procurement control that requires legal-team participation.

Combined, the bank can hold its validated state until it has chosen to re-validate against a new vendor version. The artifact is a version-pinned validation record. Each record carries: model version (your layer and vendor layer), validation date, validator signature, validation methodology reference and expiration trigger (a date or a vendor-version change event).

Ask your second line: are our production agents pinned to a specific provider model version?

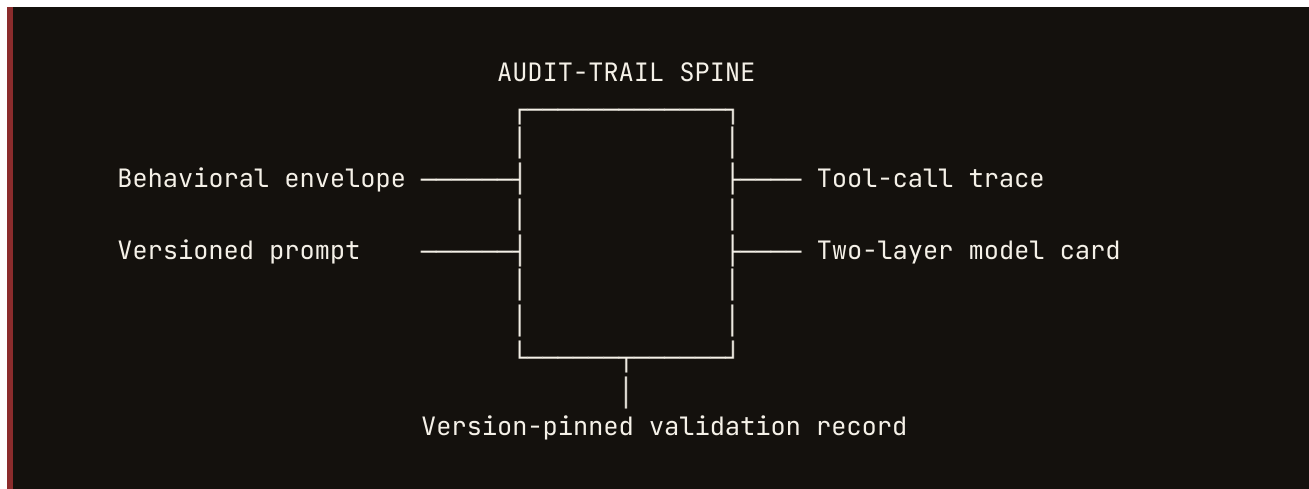
III. The Audit-Trail Spine

Across the five breakdowns, the fixes share a common data substrate. The behavioral envelope needs production output history to maintain and validate. The prompt versioning needs prompt history to satisfy change-control review. The tool-call trace is itself production capture. The two-layer model card needs vendor-version history to fire the re-validation trigger correctly. The version-pinned validation record needs the validation event history to demonstrate continuity.

All five depend on the bank capturing, for every production agent decision, an immutable record of:

- The system prompt at the time of the decision, identified by hash
- The user input
- The agent's response
- Every tool call made during the decision, with arguments and return values
- The vendor model name and version
- Your layer's deployment configuration version
- The timestamp
- The decision outcome

This is the audit-trail spine. The spine is the single substrate from which all five SR 11-7 artifacts assemble.



The spine is not a feature. It is the architecture that lets a bank produce SR 11-7-compliant documentation for an AI agent at all. Without it, each of the five fixes is a one-off effort. With it, all five are downstream views into the same canonical record.

This is the structural argument for shipping the spine before the documentation, not after. A bank that builds the documentation pack first will rebuild it every time a provider ships an update. A bank that builds the spine first generates the documentation pack on demand, at any version, with no rebuild.

The same spine produces ECOA disparate-impact reports, NIST AI RMF function-level evidence, OCC heightened-standards Appendix D risk-tier classifications and the bank's internal model inventory entries. The downstream artifacts are views; the spine is the underlying state.

IV. Implementation Roadmap

The roadmap below assumes a bank with at least one AI agent in production or near-production, a model risk function staffed for traditional model validation and a next OCC exam within twelve months. Adjust as needed for institutional context.

Days 1 to 90: Instrumentation

Stand up the audit-trail spine. Every agent decision in production writes a row. The capture schema is the eight-field record specified in Chapter III. The retention policy mirrors the existing model decision retention policy for traditional models. Storage is immutable. Access is logged.

Audit the existing agent inventory. Count agents. Identify production agents. Classify by risk tier using the institution's existing model-risk-tier scheme. Identify the highest-risk agent. This is the first one to bring into compliance.

Brief the second line of defense on the spine architecture. Get sign-off on the capture schema. Brief the third line of defense for awareness. The schema is a model-risk control. It requires the same governance review as any model-risk control.

Days 91 to 180: First Documented Agent

For the highest-risk agent, produce the five artifacts.

The **behavioral envelope specification**. Define the input distribution, the output envelope per segment and the validation methodology for the envelope. Run the validation. Sign and date.

The **versioned prompt artifact**. Hash the current production prompt. Store the hash chain back to the first production deployment. Establish change-control review for prompt updates.

The **tool-call trace structure**. Document the trace schema. Establish the retention policy and the access controls. Confirm the trace covers every production tool used by the agent.

The **two-layer model card**. Document your layer in full. Document the vendor layer with version pins and the change-notification clause from the vendor contract. State which controls live at which layer.

The **version-pinned validation record**. Pin the agent to specific vendor and your-layer versions. Run the full validation against those versions. Sign and date. Define the expiration trigger.

Run a tabletop exercise with the second line of defense. Present each artifact as if to an examiner. Confirm each would satisfy the examiner. Document gaps. Iterate.

Days 181 to 365: Scaled Coverage

Roll out the five-artifact pack to all production AI agents. Risk-tier the rollout: highest-tier agents first, lower-tier agents on a 30-60 day cadence.

Establish the ongoing-monitoring cadence. Behavioral envelope drift, prompt-version changes and vendor-version updates all flow into the spine and trigger automated alerts. Tune the thresholds against the first ninety days of production data.

Engage the third line of defense for an end-to-end audit walkthrough. The third line reviews the spine architecture, the artifact pack for at least three agents across risk tiers and the monitoring cadence.

Prepare the examiner pack. The pack is a single document that explains the spine architecture and points at the five artifacts for each in-scope agent. The examiner who arrives in the door reads this first, then walks through the artifact pack for the agents they choose to review.

Beyond Day 365

Iterate on the envelope specifications as production data accumulates. Envelopes drawn from limited data tend to be loose; envelopes drawn from twelve months of production decisions tighten meaningfully.

Update the model-inventory governance committee charter to include AI agent decisions. Risk-tier classification rules may need refinement once the institution has lived with AI agents for a year.

Begin influencing vendor procurement. Behavior-change notification clauses become a required term in foundation-model contracts. Failure-to-notify SLAs become a procurement negotiation point. The institution's voice on this matters; foundation-model providers are still calibrating what regulated customers will accept.

Appendix A: Examiner Readiness Checklist

For each production AI agent, the institution should be able to produce, on examiner request and within the standard five-business-day examiner response window:

- Two-layer model card (your layer and vendor layer), current version
- Behavioral envelope specification, current version, with last validation date
- Versioned prompt artifact, with hash chain back to first production deployment
- Tool-call trace structure document and retention policy
- Sample tool-call trace for one production decision selected by the examiner
- Population-level disparate impact report, current quarter
- Version-pinned validation record with expiration trigger
- Vendor contract excerpt showing behavior-change notification clause
- Independent validation report from the second line of defense, current period
- Internal audit report from the third line of defense, within last twelve months
- Material-issue log with remediation status

If the institution cannot produce any of the items above within the response window, that capability gap is itself a finding risk.

Appendix B: SR 11-7 Section Mapping

SR 11-7 EXPECTATION	TRADITIONAL ARTIFACT	AI-AGENT ARTIFACT
Section III: Model development	Reproducibility test suite	Behavioral envelope specification
Section III: Documentation	Self-trained model card	Two-layer model card (your layer + vendor layer)
Section IV: Validation methodology	Pre-deployment test suite	Production trace plus behavioral envelope tests
Section IV: Conceptual soundness	Decision-tree enumeration	Tool-call trace structure document
Section IV: Ongoing monitoring (feature)	Histogram per feature	Population-level outcome monitoring
Section IV: Ongoing monitoring (model)	Drift detection on features	Spine-based monitoring plus version-pin alerts
Section IV: Outcomes analysis	Internal change control review	Vendor-version change plus envelope-violation event
Section V: Vendor models	Vendor SOC 2 plus model card	Vendor layer of two-layer card plus version pin

The mapping is not one-to-one. Several SR 11-7 expectations collapse onto the spine. Several AI-agent artifacts contribute to multiple SR 11-7 expectations. The mapping is a practical guide for the validation team building the artifact pack, not a normative claim about regulatory interpretation.

Appendix C: Glossary

Audit-trail spine. The single immutable, versioned record of every production agent decision. The eight-field schema (prompt hash, user input, agent response, tool calls, vendor model version, your-layer deployment version, timestamp, decision outcome) is the substrate from which the five SR 11-7 artifacts derive.

Behavioral envelope. A statistical specification of acceptable agent behavior over a defined input distribution, written and signed before deployment, tested in production and triggering re-validation when violated. Replaces output-level reproducibility as the validation contract for non-deterministic agents.

Effective challenge. SR 11-7's term for the independent assessment of a model's design, implementation and ongoing performance by a team that is organizationally separate from the model owner. The second line of defense exists to provide effective challenge.

Tool-call trace. The captured sequence of tool invocations made by an agent during a single decision, including timestamps, tool names, input arguments and return values. The trace is the post-deployment reconstruction artifact that replaces pre-deployment behavioral enumeration.

Two-layer model card. A model card that explicitly distinguishes the bank's layer (prompts, retrieval architecture, post-processing) from the vendor layer (foundation model name, version, provider). Each layer carries its own version pins and re-validation triggers.

Version pin. A configuration control that binds a production agent to a specific foundation model version, preventing automatic propagation of vendor updates. Combined with contractual behavior-change notification, the version pin lets the bank hold its validated state until re-validation is complete.

Talk to the Founder

If you are the Chief Model Risk Officer at a US bank carrying AI agents into your next OCC exam, Caventia is taking ten design partners in 2026.

The first conversation is thirty minutes. No purchase obligation. The agenda is your specific examiner readiness, not a product pitch.

Email ashish@caventia.com or schedule directly at caventia.com/contact.

About the Author

Ashish K. Saxena is the founder of Caventia. He spent six years in financial technology, including time at Amazon's FinTech division, where he worked on fraud and lending systems serving millions of consumer-credit decisions per day. He is the author of two Amazon-bestselling books on AI ethics: *Society and the Machine* (2024 London Book Festival, first place) and *The Ethics of Artificial Intelligence*. He is a peer reviewer for the International Journal of Scientific Research, with 42 papers reviewed. He has 226 peer-reviewed citations across the literature and an h-index of 8. He was named the 2024 Best Technical Researcher of AI by the Business Innovation Awards and is listed in Marquis Who's Who.

He writes at caventia.com.

About Caventia

Caventia is the audit-trail spine for regulated AI agents. The platform ships SR 11-7 model risk artifacts for banks and FDA 510(k)-ready governance artifacts for health systems. Caventia is currently taking ten design partners across banking and healthcare.

References

1. Board of Governors of the Federal Reserve System and Office of the Comptroller of the Currency. *SR 11-7: Guidance on Model Risk Management*. April 4, 2011.
2. Office of the Comptroller of the Currency. *OCC Bulletin 2011-12: Model Risk Management*. April 4, 2011.
3. National Institute of Standards and Technology. *Artificial Intelligence Risk Management Framework (AI 100-1)*. January 2023.
4. Office of the Comptroller of the Currency. *12 CFR Part 30, Appendix D: Heightened Standards for Large Banks*. Current version.
5. Consumer Financial Protection Bureau. *Regulation B (12 CFR Part 1002), Equal Credit Opportunity Act implementing regulation*. Current version.
6. Federal Reserve Board. *Speech: Supporting Responsible Use of AI and Equitable Outcomes in Financial Services*. Governor Lael Brainard. 2021.
7. International Organization for Standardization. *ISO/IEC 42001:2023, AI Management Systems Requirements*.

This whitepaper is published by Caventia, Inc. (in formation). It is current as of the publication date and reflects the author's interpretation of the cited regulatory guidance. It is not legal advice, regulatory advice or examiner-specific guidance. Institutions should validate the framework against their own counsel and their own examiners.

© 2026 Caventia, Inc. All rights reserved. Reproduction permitted for internal use at regulated institutions; external republication requires written permission.